IMF GAP REMEDIATION — IMPLEMENTATION PLAN

PLAN-001 | Implementation Plan | Information Management Framework

Document ID: PLAN-001
Version: 1.0
Classification: Internal Use
Owner: CISO
Co-Owners: CIO | HR Director | Chief People Officer
Prepared: [DATE]
Status: Active

CONFIDENTIAL — FOR INTERNAL USE ONLY

1. Purpose and Background

Following completion of the core 48-document IMF suite (POL-001 through POL-021 with associated SOPs and Work Instructions), a systematic completeness assessment was conducted against two frameworks: ISO 27001:2022 Annex A and the NIS2 Directive (EU) 2022/2555. This plan documents all identified gaps, assigns each a remediation approach, and structures the work into three phases ordered by regulatory urgency and risk exposure.

The assessment identified 12 gaps across the two frameworks. These are categorised below and addressed across three phases totalling 13 new or amended documents, completing the suite at 61 controlled documents.

IMPORTANT: NIS2 has been in force since October 2024 with active supervision of essential entities. Life-sciences companies classified as essential entities under the health sector (Annex I) are subject to proactive supervision and fines of up to €10m or 2% of global annual revenue — with personal liability attaching to management body members. Phase 1 items are therefore time-critical.

2. Full Gap Inventory

2.1 NIS2 Gaps — Article 20 (Governance)

Gap ID	Gap Description	Source Obligation	Risk if Unaddressed	Remediation
NIS2-G01	No formal Board/management body approval act for cybersecurity measures. Board receives an annual briefing but does not formally approve the programme in a documented, evidenceable way.	NIS2 Art. 20(1)	Personal liability exposure for management body members. Evidence gap in supervision/enforcement proceedings.	GOV-001: NIS2 Governance Instrument (new companion document)
NIS2-G02	Management body members not named as a distinct training audience. POL-020 Tier 1 catches all staff including executives but does not specify the board-level cybersecurity training obligation under Art. 20(2).	NIS2 Art. 20(2)	Inability to demonstrate that management body members have 'sufficient knowledge and skills to identify risks'. Audit finding in any	AMD-POL-020: Amendment adding management body training tier

Gap ID	Gap Description	Source Obligation	Risk if Unaddressed	Remediation
			supervision review.	

2.2 NIS2 Gaps — Article 21 (Risk-Management Measures)

Gap ID	Gap Description	Source Obligation	Risk if Unaddressed	Remediation
NIS2-G03	No consolidated programme-level effectiveness assessment. Individual annual reviews exist per policy, but no aggregated KPI/KRI report to the management body demonstrating that the overall programme is working.	NIS2 Art. 21(f)	Cannot demonstrate to supervisory authority that effectiveness is assessed. Connected to NIS2-G01 — the board cannot oversee what it has not formally received.	GOV-001 (Section 4): Programme effectiveness framework and reporting cadence
NIS2-G04	No outbound vulnerability disclosure process. POL-017 addresses inbound researcher disclosure to the company, but not the company's obligation to report newly discovered vulnerabilities in its own products/services to the national CSIRT.	NIS2 Art. 21(e)	Conditional gap: material only if the company develops software products used by third parties or other sites. Low materiality for pure commercial off-the-shelf environments.	AMD-POL-017: Amendment adding Section 9 — Coordinated Vulnerability Disclosure
NIS2-G05	No communications security policy. Article 21(j) requires secured voice, video, and text communications with defined standards for approved platforms, encryption requirements, and emergency communication systems. Nothing in the suite addresses this.	NIS2 Art. 21(j)	Only Article 21 element entirely absent from the suite. No ISO 27001 analogue covers it. Directly inspectable: supervisory authorities can assess whether approved communication channels are defined and used.	POL-022/SOP-022: Communications Security Policy and Process (new)

2.3 NIS2 Gaps — Article 23 (Reporting)

Gap ID	Gap Description	Source Obligation	Risk if Unaddressed	Remediation
NIS2-G06	No NIS2-specific incident reporting framework. SOP-012 is calibrated to GDPR (72h to ICO), HIPAA, and FDA/EMA. NIS2 Art. 23 imposes a separate 3-stage timeline (24h early warning → 72h notification → 1-month final report) to a different authority (national CSIRT/NCA), with a different trigger (significant operational impact, not personal data involvement).	NIS2 Art. 23	Failure to notify a significant incident within 24 hours is a direct enforcement trigger. The authority is different from GDPR; the trigger is different; the content requirements are different. A company that follows SOP-012 correctly for GDPR may still be non-compliant with NIS2 Art. 23.	AMD-SOP-012: Amendment adding Section 10 — NIS2 Article 23 Reporting Framework

2.4 ISO 27001:2022 Gaps — Material (Category 2/3)

Gap ID	Gap Description	Source Control	Risk if Unaddressed	Remediation
ISO-G01	Threat intelligence programme ownership. CISA KEV, ISAC feeds, and vendor advisories are referenced in POL-017 but threat intelligence as a programme — ownership, sources, dissemination, use in risk decisions — is not formally owned by any document.	ISO 27001 A.5.7	Audit finding at surveillance audit. Threat intelligence inputs to the risk programme are unstructured and non-evidenced.	AMD-POL-010: Amendment adding Section 8 — Threat Intelligence Programme
ISO-G02	No IS programme independent review or assurance cadence. Every policy has an annual review, but there is no document governing the enterprise IS	ISO 27001 A.5.35	Audit finding at ISO 27001 certification or surveillance. Cannot demonstrate	GOV-001 (Section 5): IS Programme Assurance Framework

Gap ID	Gap Description	Source Control	Risk if Unaddressed	Remediation
	programme audit: third-party penetration test scope, independent assurance to the Board, or annual IS programme health assessment.		independent validation of the programme's effectiveness.	
ISO-G03	No AI governance policy. The suite prohibits shadow IT (WI-021) and references AI in POL-005 and POL-010, but there is no policy governing the use of generative AI tools by staff: approved tools, data handling prohibitions, GxP implications, IP and confidentiality obligations when using AI tools.	ISO 27001 A.5.10 / A.8.19 / emerging EU AI Act obligations	Borderline today; material within 12–18 months given FDA AI/ML guidance trajectory, EU AI Act, and EMA AI considerations. Staff using unapproved AI tools with company data creates data protection, IP, and GxP data integrity exposure.	POL-023/SOP-023: AI Governance Policy and Process (new)
ISO-G04	Contact with authorities register (5.5) and threat information sharing contacts (5.6) not formally documented. Obligations to notify FDA, EMA, ICO, SEC are addressed in individual SOPs but there is no master contact register confirming the current named contacts at each authority.	ISO 27001 A.5.5 / A.5.6	Soft audit finding. In an incident, searching for correct regulatory contacts under time pressure creates delay risk.	REF-001: Regulatory Authority and Information Sharing Contact Register (new reference document, included in GOV-001 Appendix A)

2.5 Conditional Gaps — Action Required Only if Applicable

Gap ID	Gap Description	Condition	Action if Condition is True
COND-G01	Secure Development Lifecycle (8.25–8.29). No SDLC policy governing internal software development, including GxP software customisation, API integrations, or internal tooling.	The company develops any software internally — including customising GxP systems, building internal tools, or developing software used by others.	If yes: build POL-024/SOP-024 Secure Development Lifecycle Policy. Assess GxP impact via SOP-006 if any in-house development touches validated systems. Estimated: 2 documents.

Gap ID	Gap Description	Condition	Action if Condition is True
COND-G02	Data masking and test data management (8.11). GDPR Art. 25 prohibits use of production personal data in test environments unless justified. POL-004 covers DPIA but does not define a masking standard.	Test environments exist that could use or currently do use copies of production data containing personal information.	If yes: add Section [N] to POL-004 defining the test data classification standard, approved masking/anonymisation techniques, and the approval process for any production data use in test. Estimated: 1 policy amendment.

3. Document Map — All Deliverables

13 primary deliverables across three phases. Two conditional deliverables subject to applicability assessment.

3.1 New Documents

Doc ID	Title	Type	Phase	Owner	Gaps Addressed
GOV-001	NIS2 Governance Instrument	Companion (Framework level)	1	CISO	NIS2-G01, NIS2-G03, ISO-G02, ISO-G04
POL-022	Communications Security Policy	Policy	2	CISO	NIS2-G05
SOP-022	Communications Security Process	SOP	2	Information Security	NIS2-G05
POL-023	AI Governance and Acceptable Use Policy	Policy	2	CISO / CPO	ISO-G03
SOP-023	AI Governance Process	SOP	2	Information Security	ISO-G03
REF-001	Regulatory Authority and Information Sharing Contact Register	Reference (Appendix to GOV-001)	1	CISO / Legal	ISO-G04

3.2 Amended Documents

Doc ID	Current Version	New Version	Amendment Summary	Phase	Gaps Addressed
SOP-012	v1.0	v1.1	Add Section 10: NIS2 Article 23 Reporting Framework — 3-stage	1	NIS2-G06

Doc ID	Current Version	New Version	Amendment Summary	Phase	Gaps Addressed
			reporting timeline, significant incident trigger definition, CSIRT/NCA contacts, content requirements per stage		
POL-020	v1.0	v1.1	Add management body/executive training tier. Named obligation for Board and C-suite: assessed cybersecurity training, annual completion tracking, evidence record for Art. 20(2) supervision.	1	NIS2-G02
POL-017	v1.0	v1.1	Add Section 9: Coordinated Vulnerability Disclosure — outbound disclosure to national CSIRT of vulnerabilities discovered in company-developed software. Includes CVD policy, coordinated disclosure timelines.	2	NIS2-G04
POL-010	v1.0	v1.1	Add Section 9: Threat Intelligence Programme — formal ownership of threat intelligence sources, dissemination to risk programme, IS assurance reporting cadence to Board.	2	ISO-G01

3.3 Registry Updates

Artefact	Update Required	Phase
IMF_Document_Register.jsx (REG-001)	Add GOV-001, POL-022, SOP-022, POL-023, SOP-023, REF-001. Update version numbers for SOP-012 v1.1, POL-020 v1.1, POL-017 v1.1, POL-010 v1.1.	3
RACI-001	Add rows for GOV-001 (Board approval role), POL-022/SOP-022 (comms security), POL-023/SOP-023 (AI governance). Update ISSG and Board rows for NIS2 Art. 20 obligations.	3
scan_integrity.js	Add new document IDs and generator file paths. Add amendment file paths. Update EXCLUDE patterns for any new technical terms.	3 (ongoing)

4. Phased Implementation Plan

Phase 1 — NIS2 Regulatory Compliance (Weeks 1–3)

IMPORTANT: NIS2 supervision is active. Essential entities under the health sector can be subject to proactive regulatory review. Phase 1 items address the three areas where a supervision exercise could identify personal liability exposure for management body members: absence of Board approval, absence of executive training, and absence of the NIS2-specific incident reporting process.

#	Deliverable	Owner	Dependencies	Acceptance Criteria
1	GOV-001: NIS2 Governance Instrument	CISO	None — new document	Board formally approves cybersecurity risk-management measures. Annual programme effectiveness report template in place. IS assurance framework defined. Regulatory authority contact register populated (REF-001).
2	AMD-SOP-012 → SOP-012 v1.1	Information Security	GOV-001 (for NCA/CSIRT contact references)	New Section 10 added. Significant incident trigger defined in NIS2 terms (not just GDPR terms). 3-stage notification timeline present. NCA/CSIRT contacts populated. Tested against a tabletop scenario: does the process produce a compliant 24-hour early warning?
3	AMD-POL-020 → POL-020 v1.1	CISO / CPO	GOV-001 (for training evidence requirements)	Management body training tier added (e.g., Tier 0 — Executive/Board). Annual assessed training for all management body members. Completion tracked separately from all-staff training. Evidence format defined to support Art. 20(2) supervision.

Phase 2 — Material Gap Closure (Weeks 4–8)

#	Deliverable	Owner	Dependencies	Acceptance Criteria
4	POL-022: Communications Security Policy	CISO	None — new document	Approved platform list defined. Encryption standard for external and internal communications defined. Emergency out-of-band communications standard defined (references SOP-011/012). Prohibited channels identified (e.g., personal WhatsApp for

#	Deliverable	Owner	Dependencies	Acceptance Criteria
				Restricted data discussions).
5	SOP-022: Communications Security Process	Information Security	POL-022	Approved platform register operational process defined. Annual platform review process in place. Incident response if prohibited channel used for sensitive discussion.
6	POL-023: AI Governance Policy	CISO / CPO	None — new document	Approved AI tool categories defined. Data classification rules for AI tool input enforced (Restricted data not to be processed by unapproved AI services). GxP data integrity implications addressed. IP and confidentiality obligations clear.
7	SOP-023: AI Governance Process	Information Security	POL-023	AI tool approval process defined (similar to software approval in WI-021). GxP AI use assessment in SOP-006 context referenced. Non-compliant use escalation path to POL-021 disciplinary process.
8	AMD-POL-017 → POL-017 v1.1	Information Security	GOV-001 (for CSIRT contacts)	Section 9 added: coordinated vulnerability disclosure. Outbound disclosure timeline defined. Process for notifying CSIRT of company-product vulnerabilities present. Conditional applicability statement: applies if company develops software used by third parties.
9	AMD-POL-010 → POL-010 v1.1	CISO	None	Section 9 added: threat intelligence programme. Named sources (CISA, ISACs, vendor advisories, ENISA). Dissemination process to ISSG and risk register. Annual IS programme assurance report structure defined with Board reporting cadence.

Phase 3 — Completion and Governance (Weeks 9–12)

#	Deliverable	Owner	Dependencies	Acceptance Criteria
1	IMF_Document_Regi	Information	All Phase 1 and 2	All new and amended

#	Deliverable	Owner	Dependencies	Acceptance Criteria
0	ster.jsx (REG-001) updated	Security	documents complete	documents present in the register. Version numbers correct. Domains correctly assigned.
11	RACI-001 v1.1 regenerated	CISO	All Phase 1 and 2 documents complete	New rows for all Phase 1/2 documents. Board/management body row updated with NIS2 Art. 20 approval obligations. Governance roles for AI programme and communications security present.
12	scan_integrity.js updated	Information Security	All Phase 1, 2, 3 artefacts complete	Integrity scan returns 0 errors across the full 61-document suite.
13	Conditional gap assessment	CISO / Head of Development / DPO	Business assessment	Formal yes/no decision on COND-G01 (SDLC) and COND-G02 (data masking) with documented rationale. If yes: initiate build of POL-024/SOP-024 and/or POL-004 amendment.

5. Implementation RACI

Role	Phase 1	Phase 2	Phase 3	NIS2 Art. 20 Obligation
Board / Management Body	Approve GOV-001. Formal approval of cybersecurity programme.	Receive Phase 2 progress report at ISSG.	Approve RACI-001 v1.1.	Mandatory: Board approval of risk-management measures is the obligation itself.
CISO	Own GOV-001, POL-020 amendment, SOP-012 amendment.	Own POL-022, POL-023. Co-own POL-017 and POL-010 amendments.	Own integrity scan completion.	Accountable for NIS2 compliance programme.
CIO / Data Custodian IT	Support SOP-012 amendment (NCA/CSIRT contact confirmation).	Support POL-022/SOP-022 (approved platform inventory).	Drive RACI-001 update.	Responsible for operationalising technical measures.
Information Security	Build all documents	Build POL-022,	Build REG-001	Implement and

Role	Phase 1	Phase 2	Phase 3	NIS2 Art. 20 Obligation
	in Phases 1 and 2. Maintain scanner.	SOP-022 technical detail. POL-017/POL-010 amendments.	update, scan_integrity.js update.	evidence all Art. 21 measures.
HR Director / CPO	Co-own POL-020 amendment (executive training logistics).	Support POL-023 (AI acceptable use policy).	Sign off RACI-001 update for people-facing documents.	Support Art. 20(2) management body training obligation.
Legal	Review GOV-001 for personal liability framework. Confirm NCA/CSIRT identity.	Review POL-023 for IP and confidentiality provisions.	Confirm COND-G01/G02 assessment.	Legal sign-off on Board approval mechanism.
Compliance / QA	Review SOP-012 amendment for GxP consistency.	Review POL-023 for GxP data integrity implications of AI tools.	Review RACI-001 for Compliance/QA roles in new documents.	No direct Art. 20 obligation — advisory.

6. Success Criteria — Definition of Done

Area	Success Criterion
NIS2 Art. 20 — Board approval	Board minutes or equivalent formal record confirm annual approval of the cybersecurity risk-management programme. GOV-001 signed and effective. Management body training completions recorded in LMS.
NIS2 Art. 21 — Measures	GOV-001 Section 4 effectiveness dashboard populated with first set of programme metrics. POL-022 signed off and approved platform list published to staff. POL-023 in force and AI tool approval process active.
NIS2 Art. 23 — Reporting	Tabletop exercise confirms SOP-012 v1.1 would produce a compliant 24-hour early warning to the correct NCA/CSIRT. NCA and CSIRT contacts verified and registered in REF-001.
ISO 27001 — Threat intelligence	POL-010 v1.1 Section 9 names at least two active threat intelligence sources with a defined dissemination process. ISSG meeting agenda template includes threat intelligence agenda item.
ISO 27001 — IS assurance	Annual IS programme assurance report template defined in GOV-001. First report produced within 12 months of effective date.
ISO 27001 — AI governance	POL-023 effective. Approved AI tool list published. At least one staff communication issued. LMS training module for AI governance available within 60 days (POL-020 SOP-020 trigger).
Integrity	scan_integrity.js returns 0 errors across all 61 documents. RACI-001 v1.1 and REG-001 updated.

7. Final Suite State — Post-Implementation

On completion of all three phases (and any applicable conditional items), the IMF will comprise the following document inventory:

Category	Count	Document IDs
Framework and Companion documents	7	IMF-001, EXC-001, RACI-001, GOV-001 (new), REG-001, PLAN-001, REF-001 (GOV-001 appendix)
Policies (POL)	21 + 4 amended = 21 current versions	POL-001 through POL-021 (POL-010 v1.1, POL-017 v1.1, POL-020 v1.1) + POL-022, POL-023
Standard Operating Procedures (SOP)	21 + 1 amended = 21 current versions	SOP-001 through SOP-021 (SOP-012 v1.1) + SOP-022, SOP-023
Work Instructions (WI)	3	WI-001, WI-005, WI-021
Conditional (if applicable)	0–2	POL-024/SOP-024 (SDLC) and/or POL-004 amendment (data masking)
Total (excluding conditionals)	55	55 controlled documents across the suite

— End of Document —

PLAN-001 v1.0 | [Company Name] | INTERNAL USE